

# **V0088**

# **Advanced Information Security**

# **高级信息安全**

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,  
Ajou University, Korea

# 协议 (**Protocols**)

- 简单安全协议
- 现实安全协议

# 协议 (**Protocols**)

- 人类礼仪——人类互动中遵循的规则
  - 例如：在课堂上提问->举手示意-
- 网络协议——网络通信系统中遵循的规则
  - 例如：HTTP、FTP 等。
- 安全协议——  
安全应用程序中遵循的（通信）规则
  - 例如：SSL、IPSec、Kerberos 等。

# 协议 (**Protocols**)

- 协议缺陷可能非常隐蔽。
- 一些知名的安全协议存在重大缺陷。
  - 包括 WEP、GSM 和 IPSec
- 实施错误也可能发生。
  - IE对SSL的实现存在缺陷
- 制定正确的规程并不容易.....

# 理想安全协议

- 必须满足安全要求
  - 需求必须精确明确。
- 高效性
  - 尽量减少计算需求
  - 尽量减少带宽使用、延迟等。
- 鲁棒性
  - 当攻击者试图破解它时，它也能正常工作。
  - 环境稍有变化时也能正常工作
- 易于实施、易于使用、灵活.....
- 要满足所有这些要求很难！

# 协议 (**Protocols**)

- 简单安全协议
- 现实安全协议

# 简单安全协议

- 人类安全协议：进入美国国家安全局
- 员工（工作证）/获批的外来人员（临时通行证）
- 把证件插入读卡机
- 刷卡/输入个人身份号码（证件信息）
- 检验个人身份号码是否是登录人员
  - 正确：进入大楼
  - 不正确：拦截

# 简单安全协议

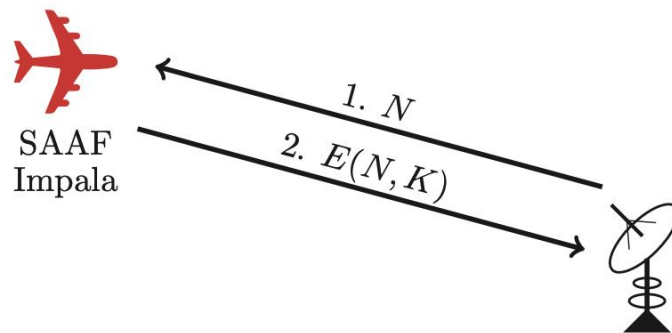
- ATM机协议
  - 插入ATM卡
  - 请输入密码
  - 密码正确吗?
    - 正确：进行后续交易
    - 不正确：吞卡，账户被锁定



# 简单安全协议

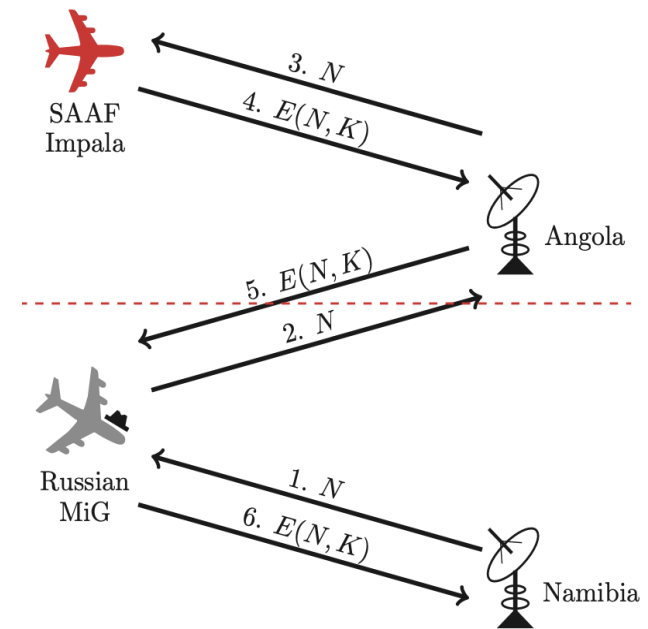
- 部队安全协议：IFF（Identification Friend or Foe, 敌我识别）协议。
- E.g., 南非空军（SAAF）在安哥拉（Angola）的战斗中的协议。
- 南非空军（SAAF）在纳米比亚和在安哥拉的古巴士兵战斗。
  - 雷达探测飞行物，发送随机数 $N$ 。
  - 所有SAAF都知道一个密钥 $K$ ，用 $K$ 加密质询 $E(N, K)$ 发送给飞行器。

- 安全吗？



# 简单安全协议

- 一个SAAF 飞行器飞入Angola 雷达（敌方）扫描区。
- 一个敌方MiG飞行器在纳米比亚雷达（SAAF）扫描区。
  - 进入范围后，纳米比亚雷达会相质询N。
  - 敌方MiG飞行器为了隐藏自己，需要发送  $E(N, K)$  。
  - MiG 给己方雷达发送N， 然后己方雷达 Angola发送N给SAAF。SAAF会送  $E(N, K)$  给己方雷达。己方雷达发送  $E(N, K)$  给MiG 飞行器。
  - 飞行器将  $E(N, K)$  给送给纳米比亚雷达。



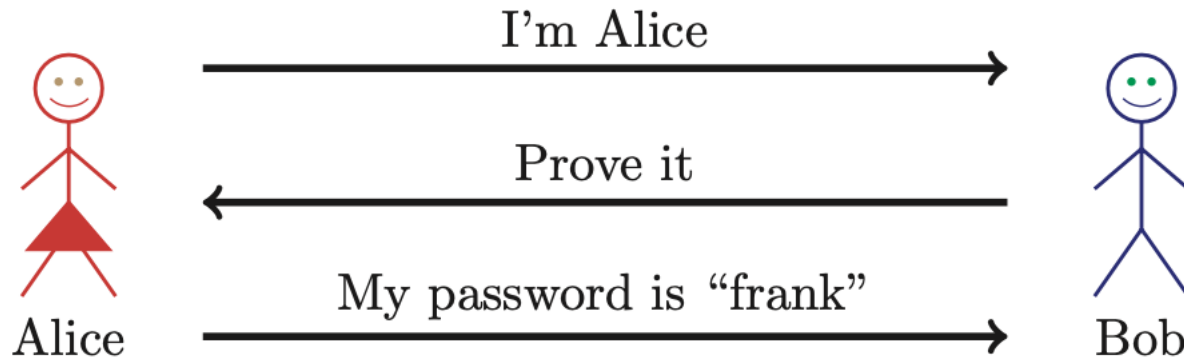
# 身份验证协议

- 爱丽丝必须向鲍勃证明自己的身份。
  - 爱丽丝和鲍勃可以是人类，也可以是**计算机**
- 可能还需要鲍勃证明他就是鲍勃（相互认证）。
- 通常需要建立**会话密钥**
- 可能还有其他要求，例如
  - 公钥、对称密钥、哈希函数.....
  - 匿名性、可信的否认、完全前向保密性等等。

# 身份验证协议

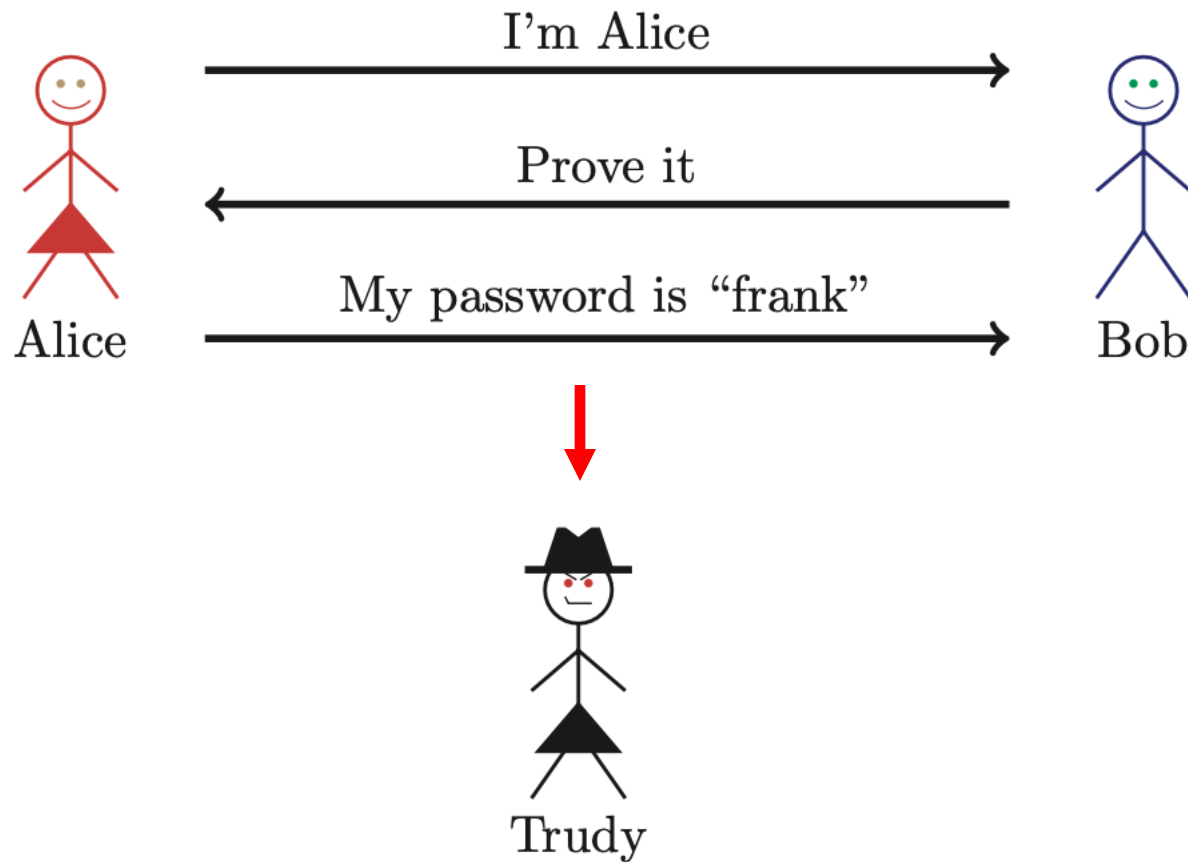
- 在独立计算机上进行身份验证相对简单。
  - 例如，使用盐值对密码进行哈希处理。
  - “安全路径”攻击、针对身份验证软件的攻击、键盘记录等都可能引发问题。
- 通过网络进行身份验证是一项挑战
  - 攻击者可以被动地观察消息。
  - 攻击者可以重放消息
  - 可进行主动攻击（插入、删除、更改）

# 简单身份验证

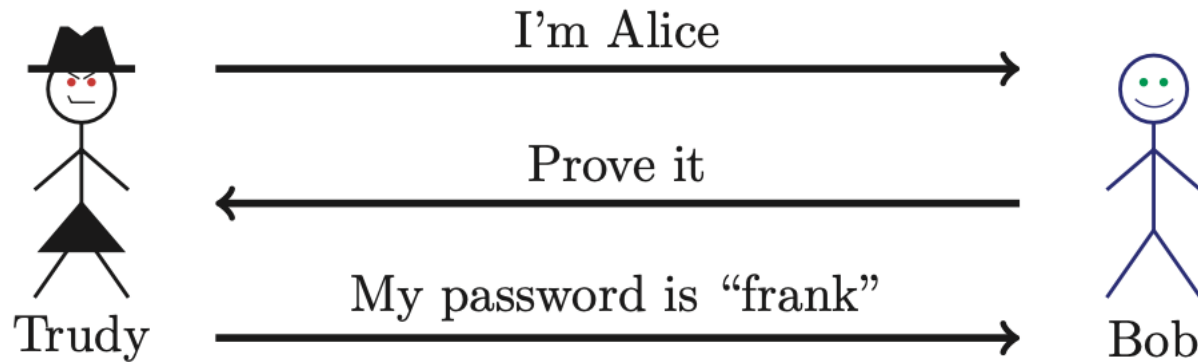


- 简单易用，可能适合独立系统。
- 但对于联网系统而言，安全性极低
  - 易受**重放**攻击（接下来的两张幻灯片）
  - 此外，鲍勃必须知道爱丽丝的密码。

# 身份验证攻击

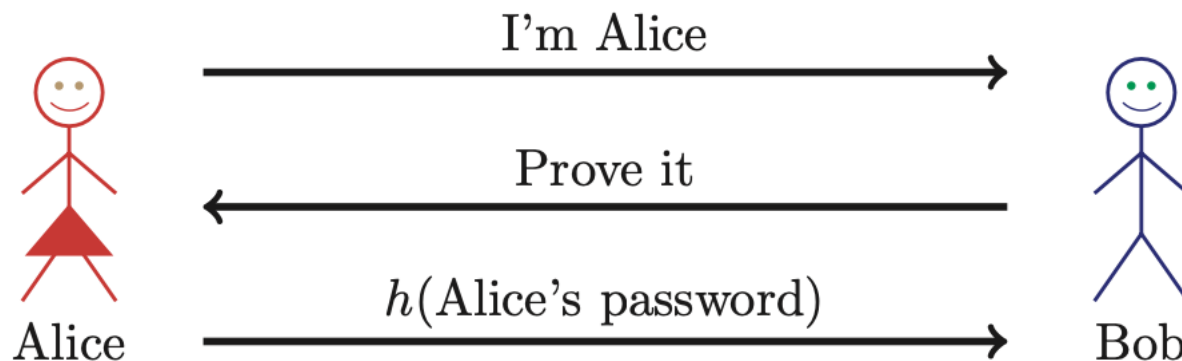


# 身份验证攻击



- **重放**攻击的例子。
- 如何防止此类事件重演？

# 更好的身份验证?



- 这种方法可以隐藏 Alice 的密码。
  - 来自鲍勃和特鲁迪
- 但仍然容易受到 **回放攻击**



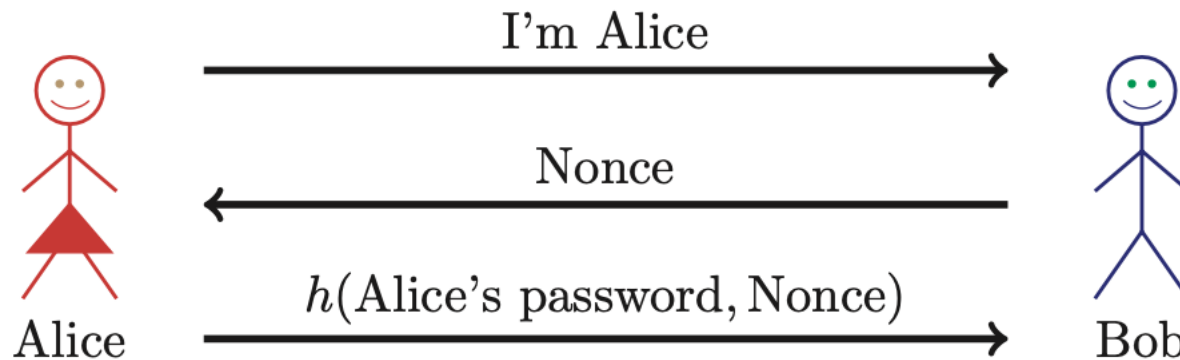
# 质询-应答机制

- 为了防止重放攻击，使用**质询-应答**机制。
  - 目标是确保“新鲜度”。
- 假设鲍勃想要验证爱丽丝的身份。
  - 鲍勃向爱丽丝发出质询
- 选择质询的目的是：
  - 无法重放
  - 只有爱丽丝才能给出正确答案
  - 鲍勃可以验证该回复

# 质询-应答机制

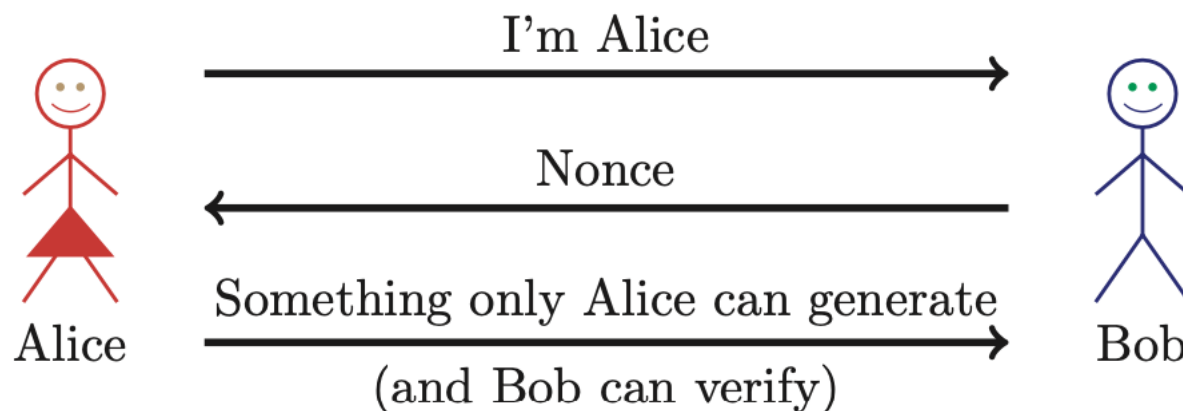
- 为确保新鲜度，可以使用**随机数**。
  - 随机数 == **n**，仅使用一次的数字
- nonce应该用什么？
  - 也就是说，质询是什么？
- 爱丽丝应该如何处理这个随机数？
  - 也就是说，如何计算响应值？
- Bob 如何验证回复？
  - 我们应该使用密码还是密钥？

# 质询-应答机制



- **Nonce** 是一大挑战
- 哈希值是应答
- **Nonce** 防止重复使用（确保新鲜度）
- 密码是爱丽丝知道的。
- 注意：Bob 必须知道 Alice 的密码才能进行验证

# 质询-应答机制



- 实际上，如何实现这一点？
- 哈希密码虽然可行，但是.....
- 这里使用加密算法可能更好（为什么？）

# 对称密钥认证

- 使用密钥K

$$C = E(P, K)$$

- 解密密文 C, 使用密钥K

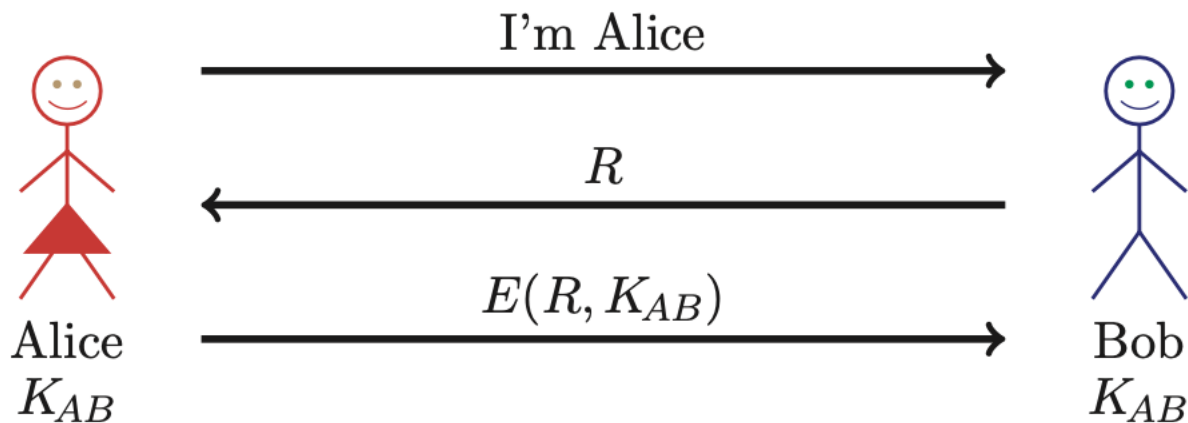
$$P = D(C, K)$$

- 这里, 我们关注的是对协议的攻击, **而不是** 对密码学的攻击
  - 因此, 我们假设加密算法是安全的。

# 对称密钥认证

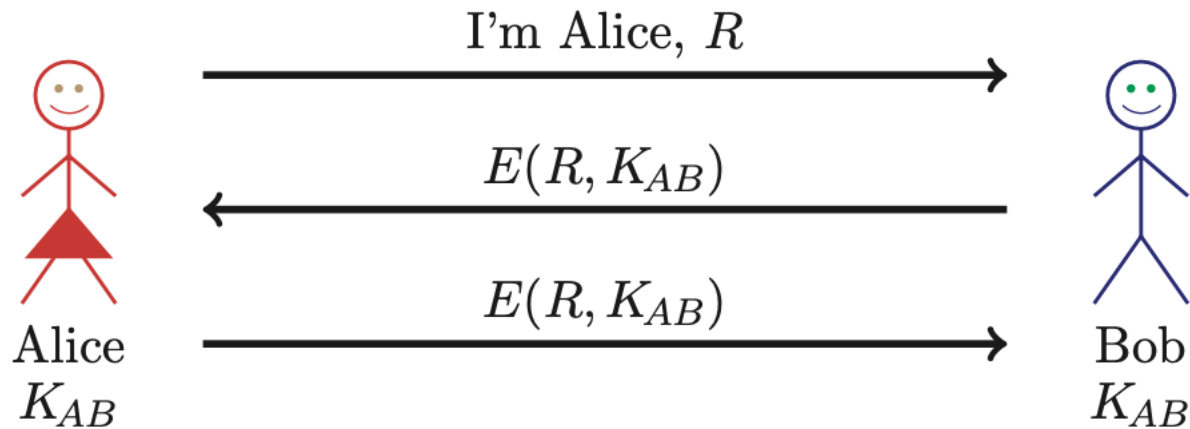
- Alice 和 Bob 共享对称密钥K
  - 只有爱丽丝和鲍勃知道的钥匙K
- 通过证明对共享对称密钥的了解来进行身份验证
- 如何实现这一点?
  - 密钥不能泄露，不允许重放攻击（或其他攻击），必须可验证，.....

# 使用对称密钥验证 **Alice** 的身份



- ❑ Bob 用来验证 **Alice** 身份的安全方法
- ❑ 但是, **Alice** 并没有验证 **Bob** 的身份。
- ❑ 那么, 我们能否实现双向认证?

# 相互认证?



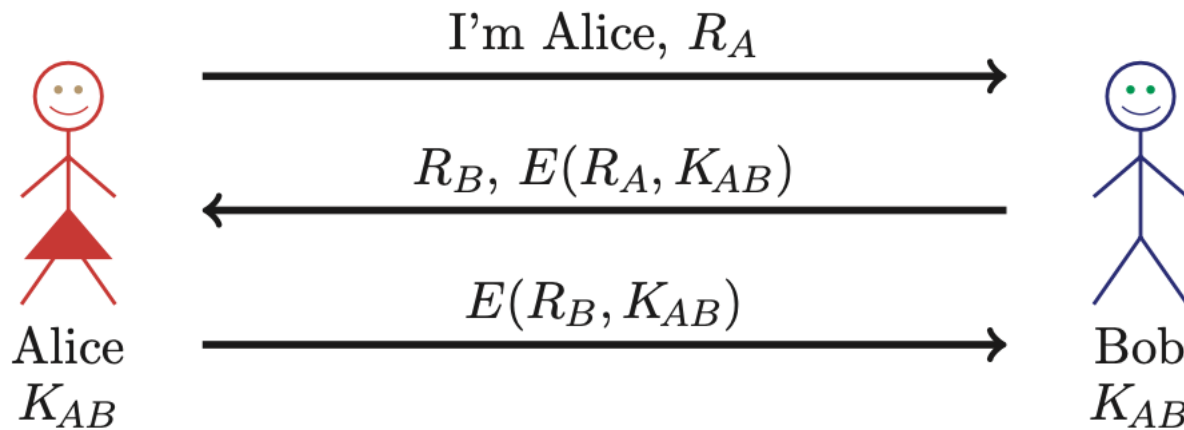
- 这张照片有什么问题?
- “Alice”可能是Trudy（或任何其他人）！



# 相互认证

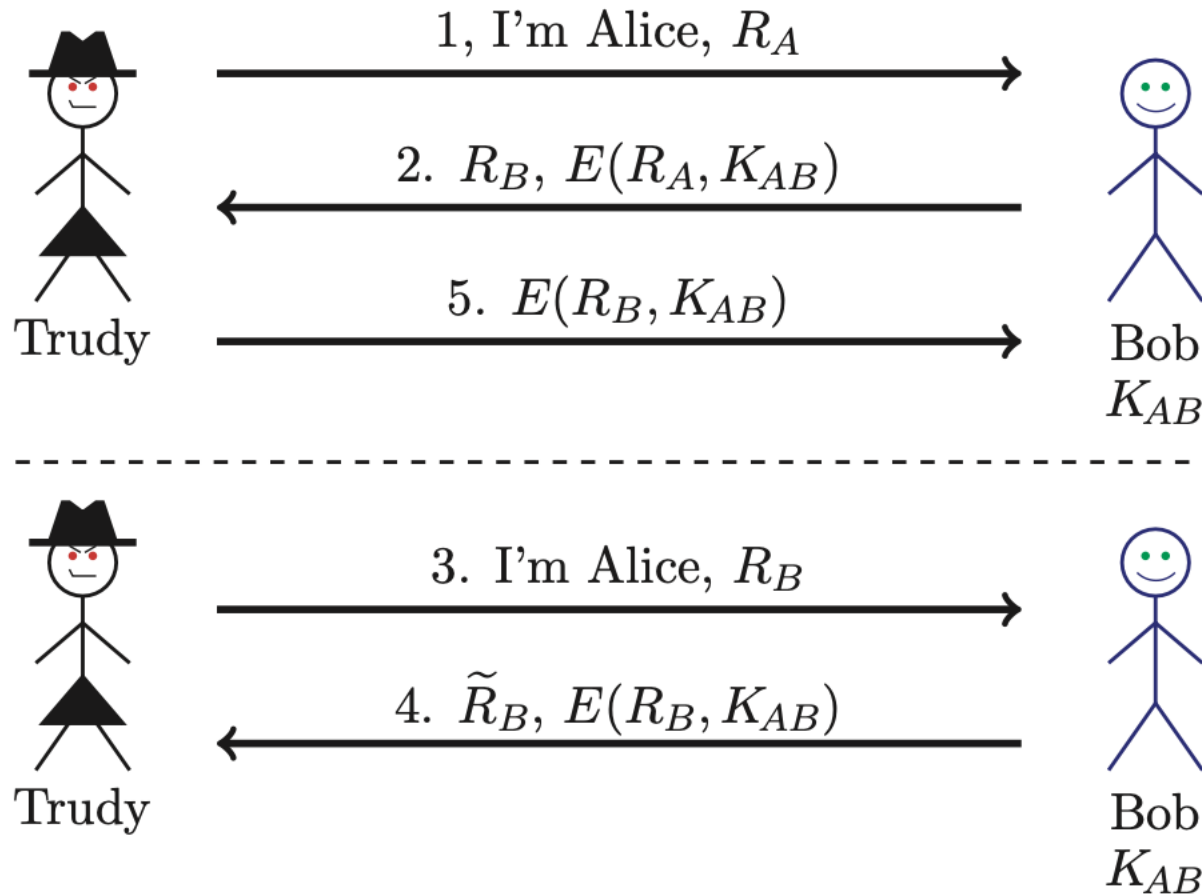
- 我们采用了**安全的单向认证协议**.....
- 相互认证最直接的做法是使用该协议两次。
  - 一次是鲍勃需要验证爱丽丝的身份。
  - 一次是爱丽丝验证鲍勃的身份。
- 这必须奏效.....

# 相互认证



- 这提供了相互认证.....
- .....是否提供了安全的相互认证？ 易受**反射**攻击
  - 下一张幻灯片

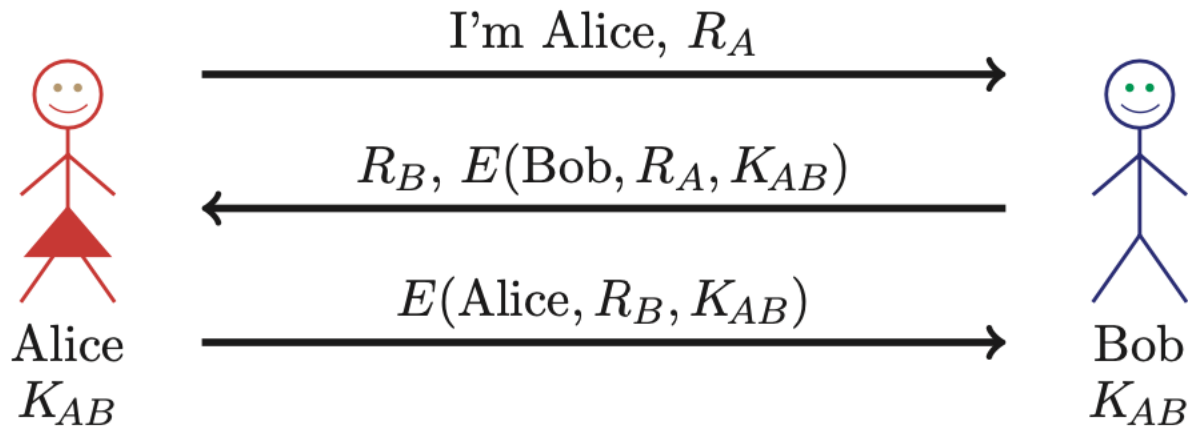
# 相互认证攻击



# 相互认证

- 我们的单向认证协议对于双向认证来说**并不安全**。
  - 协议很微妙!
  - 在这种情况下, “显而易见”的解决方案并不安全。
- 此外, 如果假设或环境发生变化, 协议可能不再安全。
  - 这是安全故障的常见原因。
  - 例如, 互联网协议

# 对称密钥相互认证

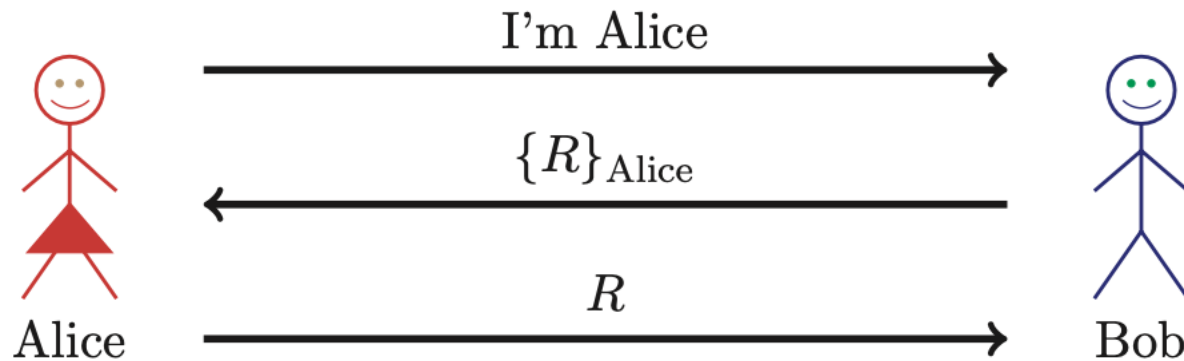


- 这些“微不足道”的改变有用吗?
- 是的!

# 公钥表示法

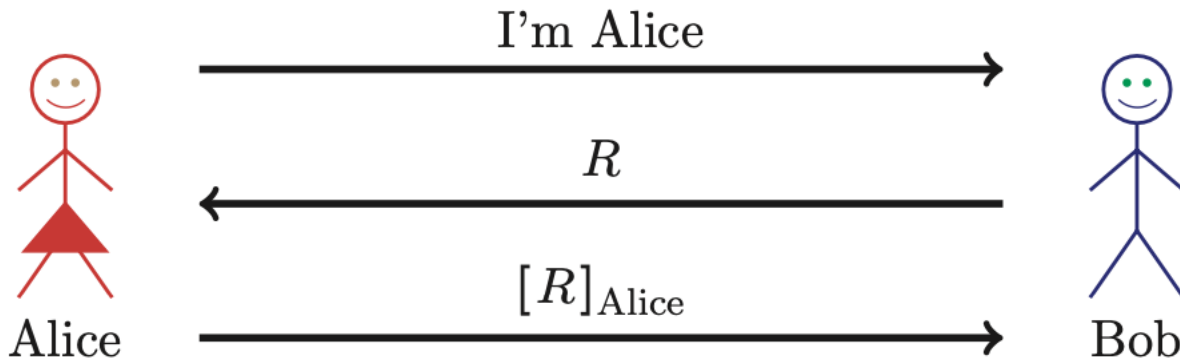
- 使用 Alice 的公钥加密M：  $\{M\}_{\text{Alice}}$
- 使用 Alice 的私钥对M签名：  $[M]_{\text{Alice}}$
- 然后
  - $[\{M\}_{\text{爱丽丝}}]_{\text{爱丽丝}} = M$
  - $\{[M]_{\text{爱丽丝}}\}_{\text{爱丽丝}} = M$
- **任何人都**可以使用Alice的**公钥**
- 只有**爱丽丝**才能使用她的**私钥**

# 公钥认证



- 这样安全吗?
- Trudy 可以让 Alice 解密任何东西!  
    为避免这种情况, 请使用两对钥匙。

# 公钥认证



- 这样安全吗?
- Trudy 能让 Alice 在任何东西上签名!
  - 与之前一样——应该有两对密钥。



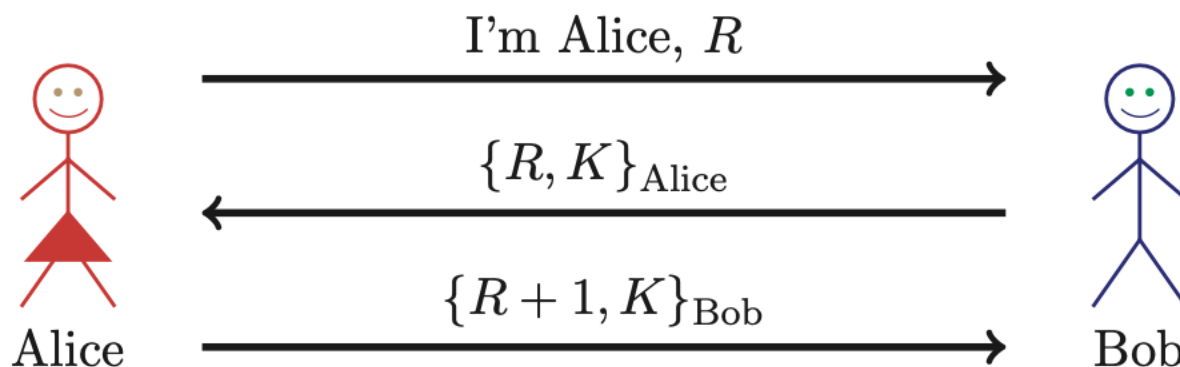
# 公钥认证

- 通常来说，使用同一对密钥进行加密和签名是不明智的做法。
- 相反，本应是.....
  - 一对密钥：只用于数据加密/解密
  - 另一对密钥：只用于签名/验证（以及身份认证相关）

# 会话密钥

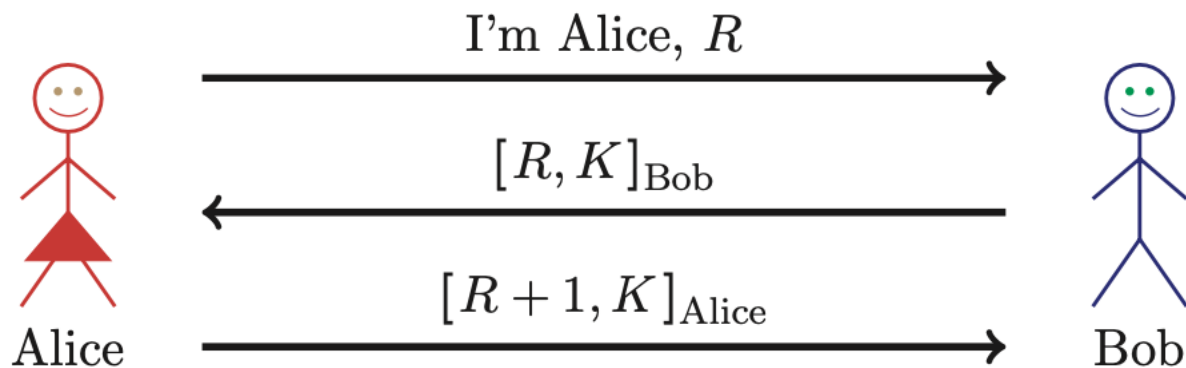
- 通常需要**会话密钥**。
  - 当前会话的对称密钥
  - 用于保密和/或诚信
- 如何进行身份验证**并**建立会话密钥（即**共享对称密钥**）？
  - 身份验证完成后，Alice 和 Bob 会共享一个会话密钥。
  - Trudy无法破解身份验证.....
  - ...而Trudy 无法确定会话密钥

# 身份验证和会话密钥



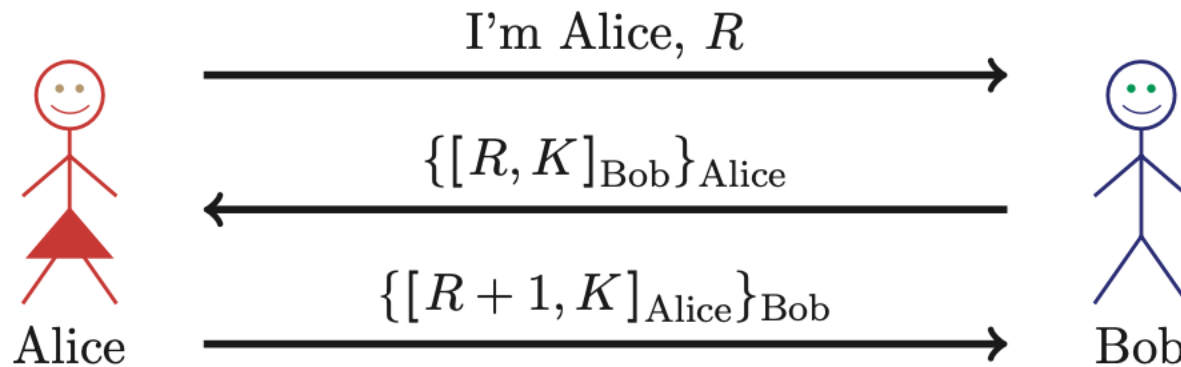
- 这样安全吗?
  - Alice 已通过身份验证, 会话密钥安全。
  - Alice 的“随机数”  $R$  对验证 Bob 的身份毫无用处。
  - 密钥  $K$  充当 Bob 向 Alice 发送的随机数。
- 没有相互认证

# 公钥认证和会话密钥



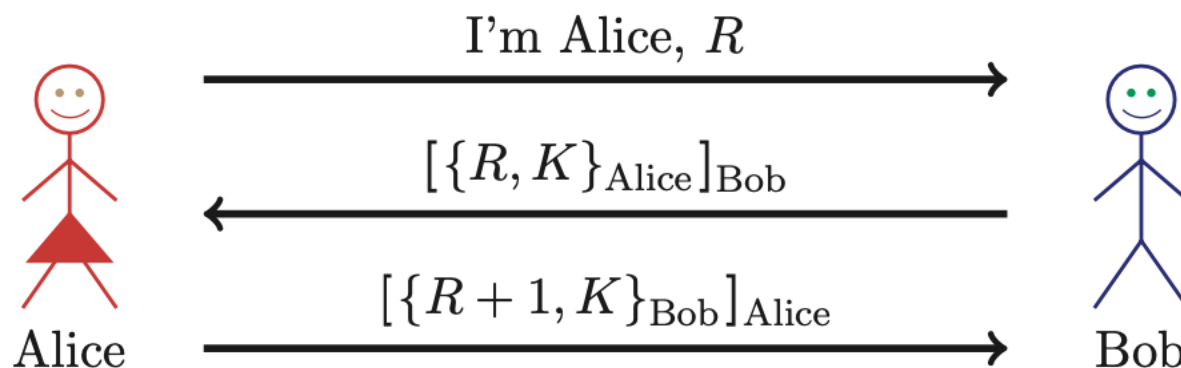
- 这样安全吗?
  - 相互认证 (很好) , 但是.....
  - ...会话密钥未受保护 (非常糟糕)

# 公钥认证和会话密钥



- 安全的双向认证和会话密钥?
- 不! 它容易受到隐蔽的中间人攻击。

# 公钥认证和会话密钥

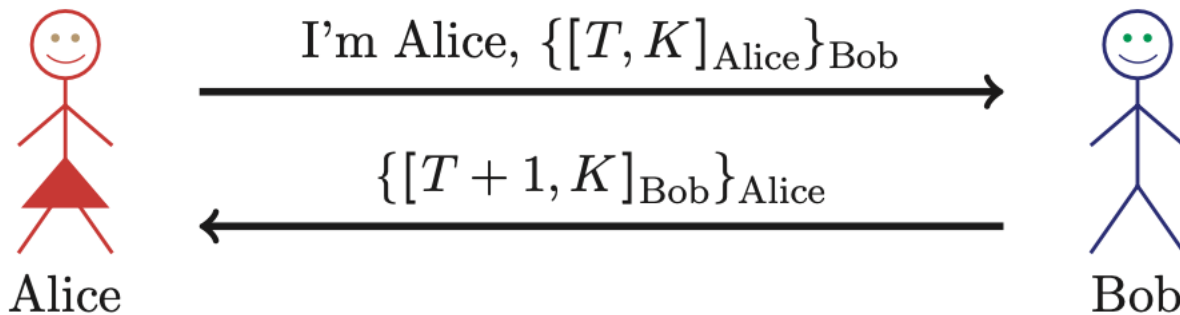


- 这样安全吗?
- 看起来没问题
  - 任何人都可以看到  $\{R, K\}_{\text{Alice}}$  和  $\{R + 1, K\}_{\text{Bob}}$

# 时间戳

- 时间戳 $T$ 由当前时间导出
- 时间戳可用于防止重放。
  - 例如，用于 Kerberos。
- 时间戳可以减少消息数量（好）。
  - 双方都事先知道的质询
- “时间”是一个安全关键参数（不好）。
  - 时钟不一致和/或网络延迟，因此必须考虑**时钟偏差**——这会带来重放攻击的风险。
  - 多少时钟偏差才算足够？

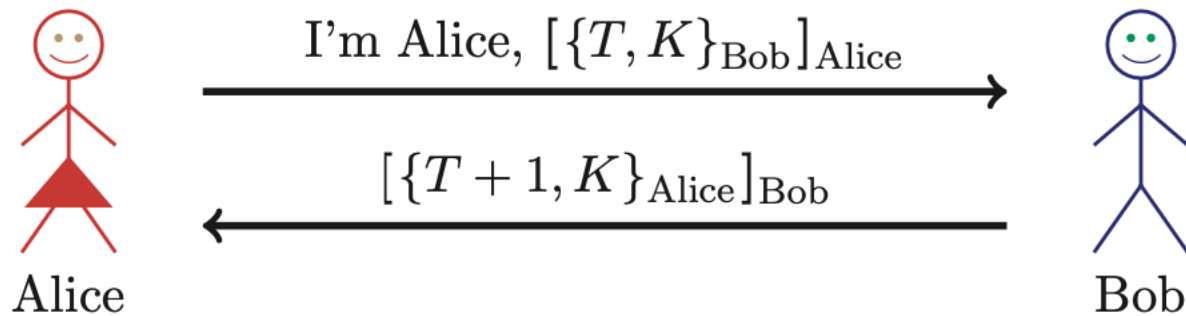
# 带时间戳的公钥认证



- ❑ 安全的双向认证?
- ❑ 会话密钥安全吗?
- ❑ 看起来没问题

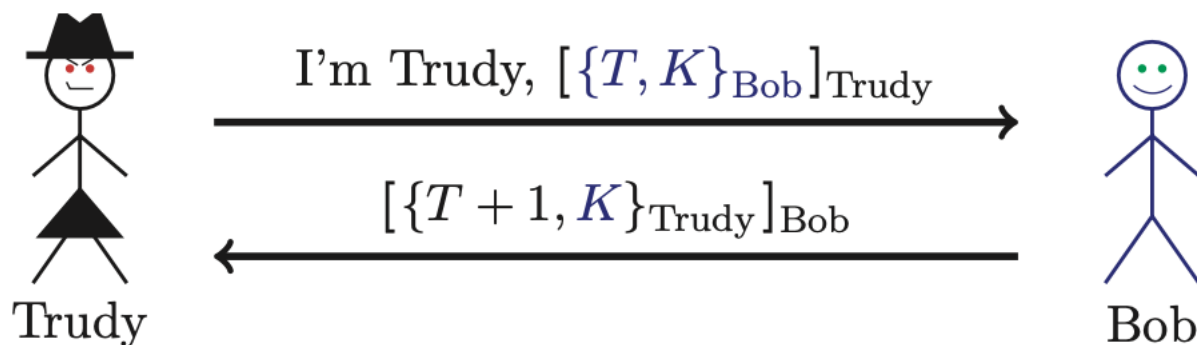


# 带时间戳的公钥认证



- ❑ 安全认证和会话密钥?
- ❑ Trudy 可以使用 **Alice** 的公钥来查找  $\{T, K\}_{Bob}$  然后发送  $[\{T, K\}_{Bob}]_{trudy}$

# 带时间戳的公钥认证

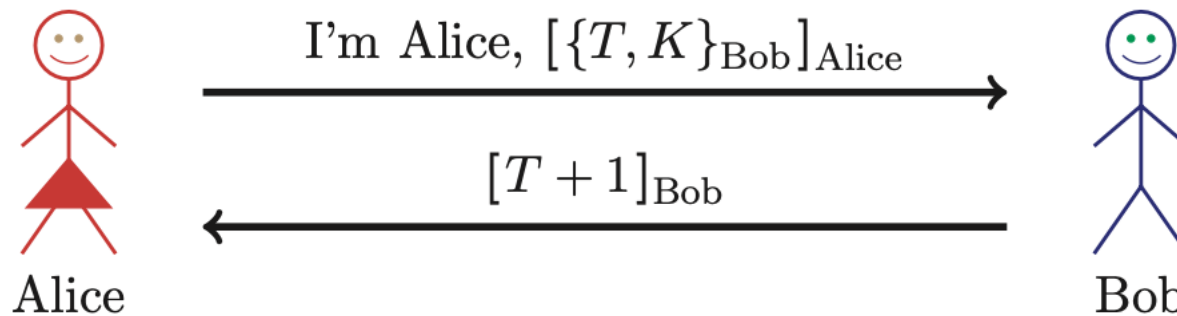


- ❑ Trudy 获取了 Alice-Bob 会话密钥K
- ❑ 注意：特鲁迪必须在时钟偏差范围内行动

# 公钥认证

- 使用 nonce 进行签名和加密...
  - 不安全
- 使用 nonce 加密和签名...
  - 安全
- 使用时间戳进行签名和加密.....
  - 安全
- 使用时间戳进行加密和签名.....
  - 不安全
- 协议有时很微妙!

# 带时间戳的公钥认证



- ❑ 这种“加密签名”方式安全吗？
  - 是的，看起来没问题。
- ❑ “签名和加密”在这里也适用吗？

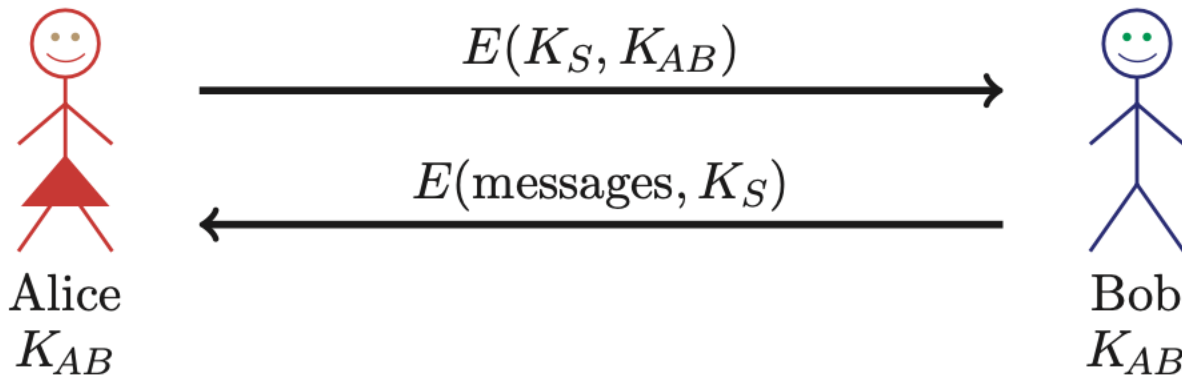
# 完美前向保密 (**Perfect Forward Secrecy**)

- PFS: 即使将来某个长期密钥被泄露, 过去的通信内容依然无法被解密
- 请思考一下这个“问题”.....
  - Alice 使用共享密钥K加密消息, 并将密文发送给 Bob。
  - Trudy 记录了密文, 之后攻击了 Alice (或 Bob) 的计算机以恢复K。
  - 然后, 特鲁迪解密了录制的消息。
- PFS: Trudy 之后无法解密已记录的密文。
  - 即使 Trudy 获得了密钥K或其他密钥。

# 完美前向保密 (**Perfect Forward Secrecy**)

- 假设 Alice 和 Bob 共享密钥K
- 为了实现完美前向保密， Alice 和 Bob 不能使用K进行加密。
- 相反，他们必须使用会话密钥 $K_S$ ，并在使用后将其删除。
- Alice 和 Bob 能否就会话密钥 $K_S$ 达成一致，从而提供 PFS?

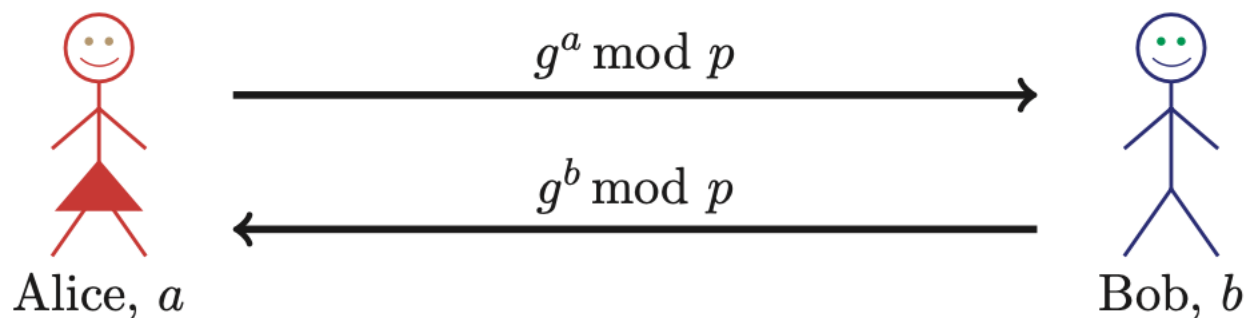
# 朴素会话密钥协议



- Trudy 可以记录  $E(K_S, K_{AB})$
- 如果 Trudy 之后获得了  $K_{AB}$ ，她就可以获得  $K_S$ 。
  - 然后，Trudy 就可以解密录制的消息了。
- 在这种情况下，不能提供完美前向保密性

# 完美前向保密

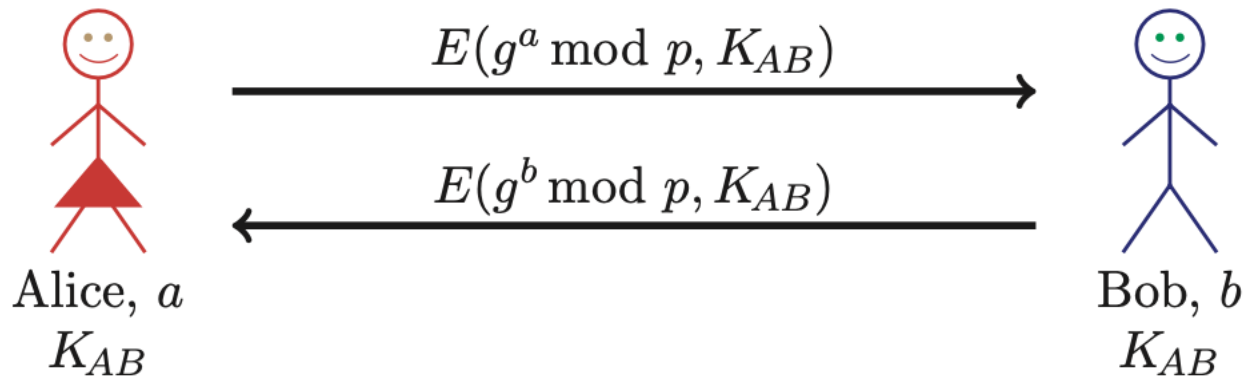
- 我们可以使用**Diffie - Hellman**法进行PFS分析。
- 回顾：公共参数  $g$  和  $p$



- ❑ 但迪菲-赫尔曼法受中间人审查的限制
- ❑ 如何获得 PFS 并预防MiM ?

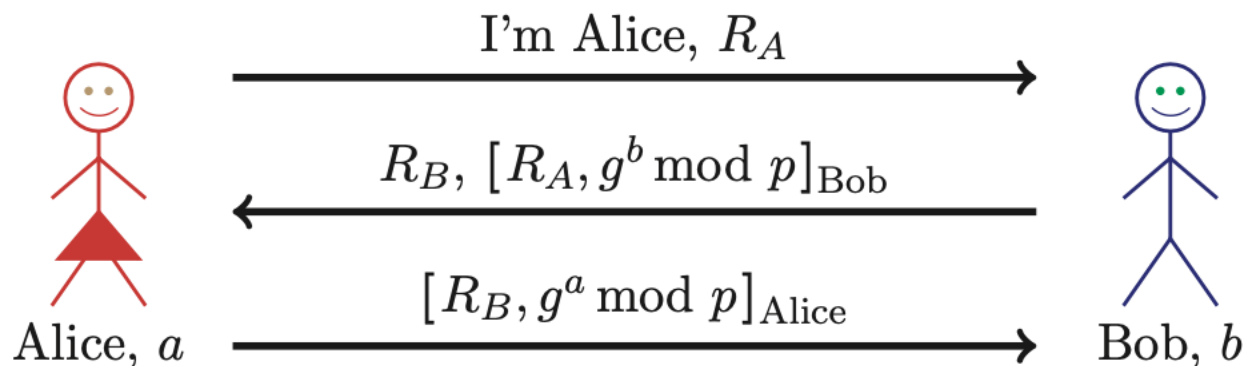


# 完美前向保密



- 会话密钥  $K_S = g^{ab} \bmod p$
- Alice 忘记  $a$  鲍勃忘记  $b$
- 这被称为**瞬态迪菲-赫尔曼法**
- Alice 和 Bob 后来都无法找回  $K_S$
- 还有其它方法可以实现 PFS 吗?

# 相互认证、会话密钥和 PFS

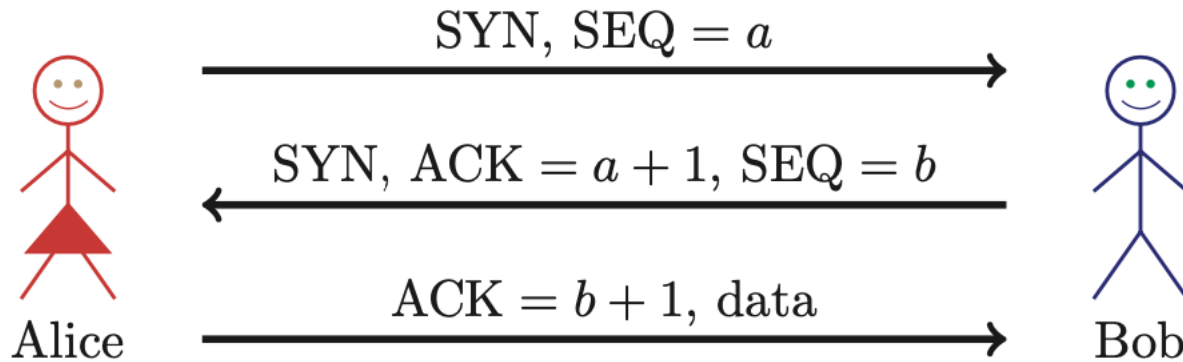


- ❑ 会话密钥为  $K = g^{ab} \bmod p$
- ❑ **Alice** 忘记  $a$  , **Bob** 忘记  $b$ 。
- ❑ 即使特鲁迪之后得知了鲍勃和爱丽丝的秘密, 她也无法找回会话密钥  $K$ 。

# 基于 **TCP** 的身份验证

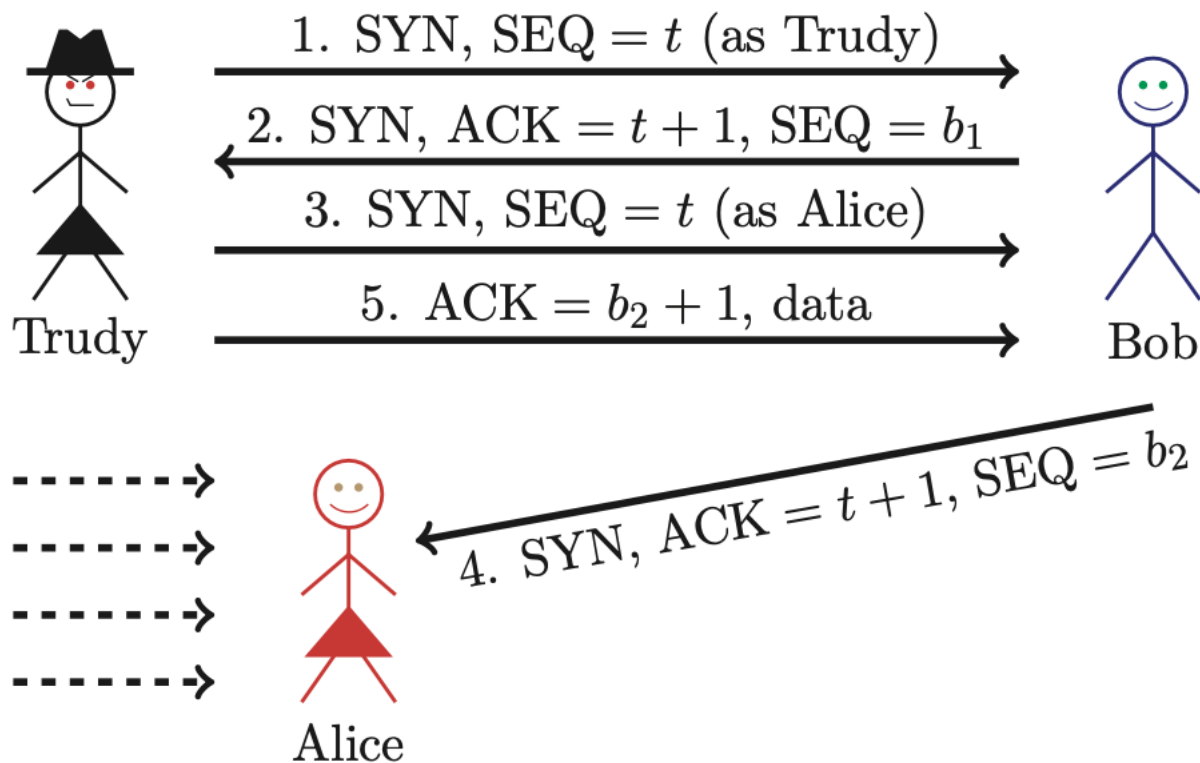
- TCP 并非设计用于身份验证协议
- 但是，TCP 连接中的 IP 地址可能被（误）用于身份验证。
- 此外，IPSec 的一种模式依赖于 IP 地址进行身份验证。

# TCP 三次握手

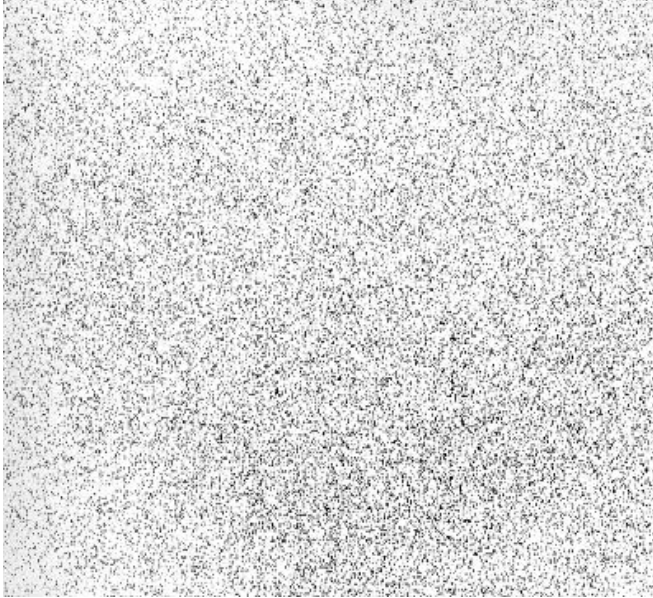


- ❑ 初始序列号：  $a$ 和 $b$ 
  - 应该是随机选择的。
- ❑ 否则， 可能会出现问题.....

# TCP认证攻击



# TCP认证攻击



随机序列数



初始序列号  
Mac OS X

- ❑ 如果初始序列号并非完全随机.....
- ❑ .....可以猜测初始序列号.....
- ❑ .....之前的攻击将会成功

# TCP认证攻击

- Trudy看不到Bob发送的内容，但她可以冒充Alice给Bob发送包裹。
- Trudy必须阻止Alice收到Bob的回复（否则连接将会断开）。
- 如果需要**密码**（或其他身份验证方式），则此攻击会失败。
- 如果身份验证依赖于TCP连接，那么攻击可能会成功。
- 依赖TCP进行身份验证是**个糟糕的主意**。

# Thank you.